

Financiera Efectiva

Gerencia de TI

Propuesta — Modelo Business-IT: Gobierno para el Desarrollo de Aplicaciones fuera de TI

Versión	6.0
Fecha	10.04.2026
Objetivo	Estrategia de TI para encuadrar, habilitar y controlar el desarrollo de software realizado por el área de Innovación de Riesgos, preservando el gobierno de infraestructura, seguridad y pase a producción en TI, en cumplimiento de las normativas SBS y de protección de datos personales.
Elaborado por	Gerencia de TI
Estado	Borrador Final
Clasificación	Uso interno

Tabla de Contenidos

Tabla de Contenidos	2
1. Contexto Estratégico	4
2. Principios rectores del modelo	4
3. Planteamiento del problema	5
3.1 Shadow IT: definición, alcance y distinción con automatización de escritorio	5
3.2 Incidente real en Efectiva	6
4. Marco Teórico	6
4.1 Governed Citizen Development	6
4.2 Automatización de escritorio vs. desarrollo full-code: el espectro de riesgo	7
4.3 Fusion teams y el Camino Estándar (Golden Path)	7
4.4 Bimodal IT y Two-Speed IT	7
5. Casos de uso y experiencias documentadas	8
5.1 Caso: European Bank — de la restricción al gobierno adaptativo	8
5.2 Otros casos internacionales Back to TOC	9
5.3 Referencias LATAM y contexto peruano	9
5.4 Cifras del sector financiero	9
6. Beneficios del modelo Business-IT	10
7. Riesgos y limitaciones del modelo	10
8. Marco regulatorio aplicable	11
8.1 SBS 504-2021 — Ciberseguridad y Seguridad de la Información	12
8.2 DS 016-2024-JUS — Protección de Datos Personales en Plataformas	12
8.3 EBA, NIST SSDF y Basel — Marcos comparables	12
9. Framework de gobierno: resumen de la Política Marco	13
9.1 Modelo de tres líneas de defensa e independencia	13
9.2 Modelo proveedor interno	14
9.3 Política marco — articulado	14
9.4 Mesa ágil e integraciones con el ecosistema TI	15
9.5 Control de dominios y gobierno de internet	15
9.6 OLA — Acuerdo Operativo de Servicio	15
9.7 Gestión de incidentes y soporte	15
9.8 Checklist de pase a producción	16
9.9 Criterios de rechazo automático	16
9.10 Comité de Arquitectura	17
9.11 Clasificación de aplicaciones (Risk Tiering)	17

9.12	Datos personales y privacidad	17
9.13	Rol de la Seguridad de la Información	17
9.14	Gobierno de IA.....	18
9.15	Metodología de desarrollo y gestión de proyectos	18
9.16	Tipos de cambio y controles aplicables.....	18
10.	Plan de acción	19
11.	Registro de riesgos del modelo	21

1. Contexto Estratégico

La unidad de Innovación de Riesgos de Financiera Efectiva cuenta con un equipo propio de desarrollo de aplicaciones para proyectos que requieren capacidades de innovación tecnológica especializada — incluyendo modelos cuantitativos, análisis de riesgo, chatbot, IA, simulaciones y canales digitales— que TI no posee en su stack actual y que su carga operativa no le permite asumir. Esta es una realidad ya en marcha.

Intentar restringir esta capacidad genera un efecto adverso: el surgimiento de soluciones fuera del control institucional ("Shadow IT"), incrementando significativamente el riesgo operativo, de seguridad y regulatorio.

El problema no es la existencia de esta capacidad fuera de TI, sino la ausencia de un modelo formal de gobierno. Debido a ello, se propone un Modelo, adaptación a nuestra realidad del modelo Governed Citizen Development (GCD).

Este documento representa la respuesta estratégica de TI: en lugar de bloquear o ignorar esa capacidad, TI establece un marco de gobierno explícito —el modelo **Business-IT**— que la habilita con controles formales. Este modelo se adopta bajo un enfoque controlado, con mecanismos de monitoreo y revisión continua de su efectividad, ajustando los controles y acuerdos a medida que el modelo madure y se identifiquen mejoras. Su sostenibilidad depende del cumplimiento de los compromisos asumidos por ambas partes y la aprobación al más alto nivel.

Consta de un Informe Ejecutivo para obtener la aprobación de Gerencia General y el área de Riesgos. Un Informe Detallado de la Propuesta (este documento) y los sustentos para ella y finalmente la Política Marco del Modelo.

NOTA: Si bien en este documento se habla del área de Innovación de Riesgos, responsable del desarrollo de la aplicación, este modelo aplica a cualquier unidad de negocios que asuma tareas de desarrollo de aplicaciones, previa autorización.

Atención: Las aplicaciones que la Gerencia de Innovación de Riesgos desarrollará son de alto riesgo. Incluyen un canal web y un chatbot orientados a clientes para el otorgamiento de créditos, con manejo de información personal, financiera, documentos e imágenes para scoring crediticio, y uso intensivo de modelos de IA. Esto eleva radicalmente el nivel de exigencia: una app de backoffice tolera controles más ligeros; un canal internet-facing que procesa datos sensibles altamente regulados exige un baseline de seguridad, segregación y evidencia mucho más robusto, en línea con lo que la SBS ya exige explícitamente para APIs y plataformas digitales.

2. Principios rectores del modelo

PRINCIPIO 1 — TI como habilitador: revisión de seguridad, no de lógica de negocio

TI no realiza revisión manual del código fuente ni de la lógica de negocio de las aplicaciones de la Gerencia de Innovación de Riesgos. Sin embargo, sí solicitará controles automatizados de seguridad y evidencias técnicas verificables —equivalentes a una revisión de código— que detecten vulnerabilidades de seguridad y validen buenas prácticas mínimas (SAST, SCA, secrets scanning). La distinción es: TI no evalúa qué hace el código fuente ni la lógica del negocio, pero sí que sea seguro. La Subgerencia de Seguridad de la Información (bajo la Gerencia de Riesgos) define las políticas, aprueba los resultados y supervisa el cumplimiento de forma independiente.

PRINCIPIO 2 — Propiedad clara y trazable

La Gerencia de Innovación de Riesgos es el Responsable de Aplicación (*Application Owner*): código, mantenimiento, corrección, documentación y soporte funcional. TI es el Custodio de Infraestructura (*Infrastructure Custodian*). La Subgerencia de Seguridad de la Información define políticas, valida controles y supervisa el cumplimiento de forma independiente. Los roles de Responsable de Aplicación y Custodio de Infraestructura están registrados en el CMDB.

PRINCIPIO 3 — Controles proporcionales al riesgo

Los requisitos de pase a producción son equivalentes a los de cualquier proveedor externo de software: Ethical Hacking, Control de Cambios, Informe GIR de Riesgo Operacional. Para canales externos con datos de clientes, los controles son más estrictos.

PRINCIPIO 4 — Cumplimiento regulatorio no negociable

Toda aplicación en producción tiene dueño formal, está catalogada, ha pasado Ethical Hacking y cumple el DS 016-2024-JUS (logs 2 años, trazabilidad). Las metodologías de desarrollo y gestión de proyectos deben estar formalmente normadas.

PRINCIPIO 5 — Ciclo de vida completo a cargo de Innovación de Riesgos

La Gerencia de Innovación de Riesgos (no el área de Riesgos en su conjunto, ni Riesgo Operacional) es responsable de:

- Mantenimientos correctivos y evolutivos.
- Atención de observaciones de seguridad (Ethical Hacking, Check-list de seguridad, auditorías, alertas de vulnerabilidad).
- Resolución de obsolescencia tecnológica (EOL de librerías, frameworks, imágenes base).
- Adaptación a requerimientos regulatorios que afecten la aplicación.
- Adecuación ante cambios en integraciones habilitadas por TI.
- Participación en pruebas de DRP.
- Participación en la investigación y resolución de incidentes, ejecutando descarte simultáneo con TI cuando el origen no es claro.

Todos estos compromisos quedan establecidos en el OLA.

3. Planteamiento del problema

3.1 Shadow IT: definición, alcance y distinción con automatización de escritorio

El **Shadow IT** es el uso de sistemas, dispositivos, software, aplicaciones o servicios fuera de la visibilidad, control o aprobación del departamento de TI. No se define por ser solo peligroso, sino por ser *desconocido o no autorizado* para TI. Su origen es casi siempre funcional: un área de negocio necesita una herramienta que TI no puede proveer a la velocidad requerida.

Es importante distinguir el Shadow IT del concepto de **automatización de escritorio**. Herramientas como RPA (Robotic Process Automation), Power Automate Desktop, macros de Excel o scripts de usuario corren en el equipo del empleado —no en servidores— con radio de impacto limitado al flujo de trabajo individual. Aunque pueden presentar riesgos menores (datos en equipos no gestionados, credenciales hardcodedas), su nivel de exposición es fundamentalmente distinto al de una aplicación desplegada en servidores con APIs expuestas a internet y datos de clientes. Estas herramientas de escritorio son el extremo de menor riesgo del espectro; el proyecto de Innovación de Riesgos se ubica en el extremo opuesto.

ISACA distingue entre **Shadow IT** ("sin conocimiento ni permiso") y **Business-IT** ("sancionado pero gestionado fuera de TI por un área de negocio"). Esta separación es el fundamento del modelo: no se puede gobernar lo invisible, pero sí lo federado con controles explícitos.

3.2 Incidente real en Efectiva

Incidente de seguridad — Aplicación desplegada por Riesgos sin conocimiento de TI

El área de Innovación de Riesgos desarrolló y desplegó una aplicación web fuera de la infraestructura de Efectiva y sin conocimiento, aprobación ni revisión de TI ni de la Subgerencia de Seguridad de la Información, que solicitaba a Funcionarios de Negocios el ingreso de información financiera de empresas de microfinanzas para análisis crediticio.

La aplicación fue descubierta durante un proceso de Ethical Hacking al detectar un dominio activo con el término "efectiva" en su URL. El equipo logró ingresar y extraer la totalidad de la información almacenada —datos de clientes y usuarios— dado que la aplicación carecía de cualquier control de acceso, protección de datos, políticas de privacidad, defensa contra bots o ataques, logs de trazabilidad o componentes mínimos de seguridad.

La extracción fue extremadamente fácil. La página estuvo "en producción" por semanas antes de ser detectada. Las consecuencias potenciales incluyeron: incumplimiento de la Ley 29733 de protección de datos personales, riesgo de multas significativas, daño reputacional y contingencias civiles y penales para la empresa, la Alta Gerencia y el Directorio. La página fue desactivada; **afortunadamente no se presentó** (hasta donde sabemos) **un incidente de seguridad**.

Este incidente es el antecedente directo que justifica el modelo Business-IT y la prohibición explícita de despliegues fuera de la infraestructura de Efectiva.

4. Marco Teórico

Este capítulo presenta los principales modelos teóricos y marcos conceptuales de la industria que sirven como referencia y fundamento para el modelo Business-IT propuesto. Su contenido es de naturaleza referencial: describe cómo la industria ha abordado el problema del desarrollo de software fuera de TI en organizaciones de distinta naturaleza y escala. Estos modelos no aplican directamente a Financiera Efectiva ni son adoptados en su totalidad; son la base conceptual sobre la cual se construyó el modelo Business-IT, adaptado a la realidad regulatoria, operativa y organizacional de la empresa.

4.1 Governed Citizen Development

El **Citizen Development** es la práctica por la cual empleados fuera de TI construyen aplicaciones para resolver necesidades de su propio negocio. En su forma no gobernada es Shadow IT con código. En su forma madura —el **Governed Citizen Development (GCD)**— es un canal legítimo y controlado de innovación, normalmente asociado a herramientas low-code/no-code y Centros de Excelencia.

El caso de Efectiva no es GCD puro: es desarrollo full-code para un canal externo crítico con uso intensivo de IA. En términos de madurez y complejidad, esto se aproxima más al concepto de **fusion teams** (Gartner): equipos multidisciplinarios donde negocio y tecnología co-lideran la entrega con responsabilidad compartida por outcomes y cumplimiento. El modelo Business-IT recoge el espíritu del GCD —habilitar con controles, no bloquear— pero lo opera con el rigor de un canal crítico regulado.

1. Shadow IT no controlado (estado origen): Apps desplegadas fuera de la infraestructura de Efectiva, sin aprobación de TI. El incidente de la sección anterior es el ejemplo concreto.

2. Shadow IT formalizado (estado intermedio): TI cataloga las apps existentes y asigna dueños. El riesgo es conocido pero los controles son reactivos.

3. Modelo Business-IT (estado objetivo): La Gerencia de Innovación de Riesgos desarrolla dentro de guardrails explícitos sobre infraestructura gobernada por TI, con pipeline CI/CD, Ethical Hacking, Control de Cambios y OLA formal. TI es habilitador y custodio técnico.

4.2 Automatización de escritorio vs. desarrollo full-code: el espectro de riesgo

Tipo	Ejemplos	Dónde corre	Datos típicos	Nivel de control
Automatización de escritorio	RPA, Power Automate Desktop, macros Excel/VBA	Equipo del usuario — no servidores	Internos, limitados	Bajo — Política de uso + inventario
Low-code / No-code	Power Apps, Airtable, automatizaciones SaaS	SaaS cloud del proveedor	Internos / potencialmente sensibles	Medio — Homologación de plataforma + revisión de datos
Full-code backoffice	Scripts Python/R, dashboards internos, modelos analíticos	Servidores internos o cloud	Internos, operativos	Medio-Alto — Checklist de pase, Ethical Hacking
Full-code canal externo con IA	Web de crédito, chatbot con LLM, scoring en producción	Cloud pública, internet-facing	Datos de clientes, financieros, biométricos	Crítico — Todos los controles del modelo Business-IT

4.3 Fusion teams y el Camino Estándar (Golden Path)

El **Camino Estándar (Golden Path)** es un conjunto de herramientas, patrones y pipelines soportados y pre-configurados por TI, diseñados para que "hacer lo correcto sea lo más fácil". El equipo de Innovación de Riesgos que desarrolla dentro del Camino Estándar obtiene soporte acelerado de TI, plantillas listas y controles de seguridad automáticos incorporados.

Soluciones fuera del Camino Estándar: La Gerencia de Innovación de Riesgos puede desviarse del Camino Estándar si justifica técnicamente la necesidad, pero deberá asumir controles adicionales de evidencia y no podrá escalar incidentes a TI por limitaciones derivadas de su desviación. Esta regla se aplica de forma explícita para prevenir que la excepción se convierta en norma. En AWS, el Camino Estándar se implementa con multi-account, landing zone y guardrails preventivos/detectivos (Control Tower).

4.4 Bimodal IT y Two-Speed IT

Tema	Modo 1 — TI tradicional	Modo 2 — Business-IT (Innovación de Riesgos)
------	-------------------------	--

Tema	Modo 1 — TI tradicional	Modo 2 — Business-IT (Innovación de Riesgos)
Enfoque	Estabilidad, confiabilidad, eficiencia	Agilidad, innovación, velocidad
Gobierno	Planes pre-aprobados, ITSM formal	Iterativo, con gates obligatorios en producción
Propietario del código	TI	Innovación de Riesgos (Responsable de Aplicación)
Infraestructura	TI	TI (AWS · Camino Estándar)
Pase a producción	Control de Cambios TI	Control de Cambios TI + gates de seguridad, privacidad y riesgo operacional

5. Casos de uso y experiencias documentadas

5.1 Caso: European Bank — de la restricción al gobierno adaptativo

Problema

47 aplicaciones no catalogadas en producción, desarrolladas por Riesgos de Crédito y Tesorería en Python, R y Excel VBA, procesando datos de clientes sin ningún control formal.

Respuesta restrictiva y su fracaso

TI bloqueó librerías y exigió adquisición estándar. Resultado: proyectos regulatorios bloqueados, insatisfacción que escaló al Directorio, y analistas usando equipos personales —empeorando el riesgo real. La lección: la restricción sin alternativa no elimina el Shadow IT, lo vuelve más peligroso.

Modelo adoptado

Sandbox aprobado con librerías pre-aprobadas, proceso de homologación con SLA de 10 días, pipeline CI/CD con gates automáticos, y OLA formal que separaba responsabilidades de mantenimiento de las de infraestructura.

Resultados (12 meses)

Métrica	Antes	Después
Apps no catalogadas en producción	47	3 (en formalización)
Tiempo de aprobación de herramientas	45 días	10 días
Incidentes de seguridad por Shadow IT	4 en 12 meses	0
Satisfacción de Riesgos con TI	2.1/5	4.0/5

Métrica	Antes	Después
Observaciones del regulador (EBA)	2 abiertas	0

Fuente: ISACA Journal, Vol. 6, 2024 – “Navigating the Shadows”. Banco europeo bajo supervisión EBA y DORA.

5.2 Otros casos internacionales Back to TOC

5.2.1 Itaú Unibanco (Brasil) — Squads con Platform Engineering

Squads propios en Riesgos y Wealth Management desde 2018. TI provee infraestructura como APIs (despliegue, monitoreo, secretos, base de datos). El squad consume servicios pero no controla la plataforma. TI no revisa el código fuente ni la lógica de negocio de las aplicaciones, pero controla los guardrails del pipeline.

5.2.2 Bancolombia (Colombia) — CoE de Analytics

Centro de Excelencia compartido entre Riesgos y TI. Los modelos son propiedad de Riesgos pero deben pasar por el comité de arquitectura de datos antes de conectarse a sistemas de decisión. Supervisado por la SFC.

5.2.3 BBVA (España / Perú) — Modelo de producto con TI embebido

Áreas de Riesgos con tech leads y equipos de ingeniería propios. Infraestructura cloud centralizada gobernada por TI Group. Los equipos despliegan a través del pipeline de TI central cumpliendo estándares de ciberseguridad del grupo.

5.2.4 JPMorgan Chase (USA) — Controlled Innovation Zones

Entornos de producción aislados con controles mínimos automáticos (WAF, logging, IAM). Las apps en estas zonas no pueden conectarse al core bancario sin aprobación completa. Bajo supervisión del OCC.

5.2.5 BCP, HSBC — Citizen Development con Microsoft Power Platform

Casos de adopción de citizen development (low-code) con Centros de Excelencia y gobierno. El mecanismo de CoE/guardrails es transferible al modelo full-code de Efectiva en la estructura de aprobación y catálogo de herramientas.

5.3 Referencias LATAM y contexto peruano

No existe un caso peruano públicamente documentado de implementación formal del modelo. Sin embargo, el antecedente propio de Efectiva y los requisitos explícitos de la SBS 504-2021 y el DS 016-2024-JUS hacen que este marco sea una necesidad regulatoria, no solo una buena práctica de gobierno

5.4 Cifras del sector financiero

Métrica	Valor	Fuente
Líderes de riesgo financiero que citan software no aprobado como preocupación #1	42%	e2e-assure 2025
Empleados que usan herramientas IA no aprobadas en finanzas	41%	e2e-assure 2025
Empleados que desconocen las políticas de IA pese a que el 80% de líderes cree tenerlas	47%	e2e-assure 2025

Métrica	Valor	Fuente
Apps corporativas no conocidas por TI en la empresa promedio	80-90%	Grip Security 2025
Ataques exitosos sobre Shadow IT	1 de cada 3	Gartner

6. Beneficios del modelo Business-IT

Para Innovación de Riesgos — Autonomía con respaldo institucional

Puede desarrollar con las tecnologías especializadas que necesita, con infraestructura enterprise y soporte de plataforma garantizado, sin depender del roadmap de TI.

Para TI — Gobierno sin sobrecarga operativa

TI deja de ser responsable del desarrollo de aplicaciones que no domina ni tiene capacidad de asumir. Se enfoca en infraestructura, seguridad y el Camino Estándar.

Para la Institución — Velocidad de innovación regulatoria

Modelos IFRS 9, scoring crediticio con IA, canales digitales pueden avanzar a la velocidad del negocio y del regulador sin bloquear el backlog de TI.

Para el Regulador — Trazabilidad y auditoría completa

Todas las apps están catalogadas, tienen dueño formal, han pasado Ethical Hacking y cumplen DS 016-2024-JUS. El modelo es más auditable que el Shadow IT que existía antes.

7. Riesgos y limitaciones del modelo

Riesgo	Probabilidad	Impacto	Mitigación
Repetición del incidente: app desplegada fuera de infraestructura Efectiva	Media	Crítico	Prohibición explícita en política marco. Gobierno de dominios. Cláusula de incumplimiento en OLA.
Canal externo sin análisis de vulnerabilidades (exigido por SBS 504-2021)	Media	Crítico	Gate obligatorio en checklist: pentest + SCA de runtime/dependencias.
Ambigüedad de responsabilidad ante SBS en incidente	Media	Crítico	OLA con roles explícitos (Responsable de Aplicación / Custodio de Infraestructura) en CMDB.

Riesgo	Probabilidad	Impacto	Mitigación
Incumplimiento DS 016-2024-JUS: logs 2 años, trazabilidad	Media	Crítico	Gate de privacidad en Checklist. CloudWatch retención 2 años mínimo.
Uso de IA sin homologación o envío de datos a LLMs externos	Alta	Crítico	Proceso de homologación en Comité de IA y Comité de Arquitectura. OWASP LLM Top 10. Política de Seguridad en el Uso de IA. Ver sección 7.11 y 7.12.
Sesgo algorítmico en modelos IA crediticia sin evaluación independiente	Media	Crítico	Evaluación periódica por Gerencia de Riesgo Operacional. Documentación de explicabilidad (XAI). Comité de Gobierno de IA.
Key-man risk: desarrollador clave deja la Gerencia de Innovación de Riesgos	Media	Crítico	Documentación obligatoria como gate. Mínimo 2 responsables por app.
Metodología de desarrollo de Innovación de Riesgos no normada — observación SBS	Media	Alto	Normalización formal antes del inicio del proyecto. Ver sección 7.13.
Fricción en Comité de Arquitectura genera shadow IT paralelo	Media	Medio	SLA 15 días. Catálogo pre-aprobado. Camino Estándar reduce solicitudes.
Deuda técnica en librerías/modelos de IA no actualizada	Alta	Alto	SLAs de remediación en OLA. Revisión anual. SCA automático en pipeline.
Independencia de evaluación comprometida (tres líneas)	Media	Alto	Gerencia de Innovación de Riesgos desarrolla; Gerencia de Riesgo Operacional coordina el GIR con todas las áreas de segunda línea. Ver sección 7.0.
Proliferación: otras áreas exigen el mismo tratamiento sin controles	Media	Medio	Política marco aprobada por Directorio con alcance delimitado.

8. Marco regulatorio aplicable

Posición regulatoria

La SBS no prohíbe el modelo Business-IT. Sin embargo, las normas peruanas exigen explícitamente controles que el Shadow IT no satisface: análisis de vulnerabilidades y pruebas de penetración para APIs (SBS 504-2021), logs de 2 años con trazabilidad en plataformas digitales (DS 016-2024-JUS), e inventario de aplicaciones con enfoque basado en riesgo (EBA). El modelo Business-IT es la forma de cumplir estas exigencias sin bloquear la innovación.

8.1 SBS 504-2021 — Ciberseguridad y Seguridad de la Información

Tema	Relevancia para el modelo
APIs para servicios en línea	Exige cifrado, control de accesos, monitoreo, prácticas de desarrollo seguro de API, análisis de vulnerabilidades y pruebas de penetración. El análisis de vulnerabilidades es obligatorio incluso si TI no revisa el código fuente de la aplicación.
Servicios en nube	Políticas de seguridad, segregación de redes, evaluación de logs, capacitación. Para servicios significativos: estrategia de salida, inventario de subcontratación y evidencia anual de controles (tipo SOC 2).
Gestión de incidentes	Exige capacidades y procedimientos para incidentes y preservación de evidencias. El OLA define el proceso de respuesta conjunta TI-Innovación de Riesgos.
Gobierno de IA	El uso intensivo de modelos de IA debe estar cubierto por la Política de Seguridad en el Uso de IA de Efectiva y por controles específicos de seguridad de sistemas de IA, supervisados por la Subgerencia de Seguridad de la Información y el Comité de Gobierno de IA.

8.2 DS 016-2024-JUS — Protección de Datos Personales en Plataformas

- Control de accesos, autenticación y revisión periódica de privilegios (mínimo semestral)
- **Logs de interacción con trazabilidad**, conservación mínima de **2 años**
- Para originación de crédito con perfilamiento/scoring y grandes volúmenes de datos sensibles: **designación obligatoria de Oficial de Datos Personales** y evaluación de impacto de privacidad (DPIA)
- Para tratamiento tercerizado: no ceder titularidad del banco de datos, asegurar confidencialidad, integridad y disponibilidad, con destrucción de información al finalizar el servicio

Implicación directa: El pase a producción del canal web/chatbot no se satisface solo con QA/UAT y Ethical Hacking. El DS 016-2024-JUS exige evidencia de privacidad, trazabilidad y control de accesos como requisitos legales. El checklist de pase a producción incluye un gate de privacidad explícito.

8.3 EBA, NIST SSDF y Basel — Marcos comparables

- **EBA:** Exige que los procesos de adquisición/desarrollo/mantenimiento apliquen también a sistemas desarrollados por usuarios finales fuera de TI, con enfoque basado en riesgo, registro, segregación de ambientes y gestión formal de cambios.
- **NIST SSDF (SP 800-218):** Prácticas de desarrollo seguro integrables a cualquier metodología. El enfoque es "evidencias y controles repetibles", compatible con el modelo de caja negra de Efectiva.
- **Basel Committee on Banking Supervision:** La resiliencia operativa como resultado de gestión efectiva del riesgo operacional. El canal de crédito digital debe estar en el BCP/DRP.

9. Framework de gobierno: resumen de la Política Marco

La Política Marco del modelo Business-IT se presenta en su versión completa y detallada en el **Anexo — Política de Business-IT**, documento que acompaña a este informe. Dicho Anexo es el instrumento normativo vinculante que debe ser aprobado por el Directorio o el Comité de Riesgos y TI para que el modelo entre en vigor. Su aprobación formal constituye la acción más importante del proceso.

Este capítulo presenta un resumen ejecutivo de cada sección de la Política, con el propósito de ofrecer una visión de conjunto antes de la lectura del Anexo. No reemplaza ni resume el contenido normativo; lo introduce.

Principio de alcance — qué y quién, no cómo

Esta normativa establece el qué (grupos de control obligatorios, criterios de bloqueo de gobierno, comités) y el quién (roles, responsabilidades, flujos de aprobación). Los controles técnicos específicos — herramientas, estándares, umbrales y procedimientos de verificación— son definidos y mantenidos por la Política de Seguridad de la Información, la metodología CI/CD y los procedimientos de pase a producción institucionales. Ante cualquier discrepancia en materia de controles técnicos, prevalece lo establecido en dichos instrumentos especializados.

Los comités mencionados en esta normativa tienen propósitos distintos y no solapados:

- El **Comité de Arquitectura** actúa en la etapa de evaluación previa: aprueba el stack tecnológico y las herramientas antes de su uso en cualquier proyecto.
- El **Comité de Cambios (CAB)** actúa en el pase a producción: aprueba cada despliegue dentro del pipeline técnico-operativo.
- El **Comité de Gobierno de IA** no es definido por esta normativa — solo se referencia y se alinea a él, pues su regulación está cubierta por la Política de Seguridad en el Uso de Inteligencia Artificial de Efectiva.

Nivel de aprobación requerido: La Política Marco requiere aprobación del Directorio o del Comité de Riesgos y TI conjuntamente. Sin esta aprobación, el modelo carece de respaldo institucional ante la SBS y no puede entrar en vigor.

9.1 Modelo de tres líneas de defensa e independencia

Organigrama real de Financiera Efectiva

El modelo de gobierno refleja la siguiente estructura organizacional:

- **Gerente de TI** → Gerente Corporativo de Tecnología y Servicio al Cliente → CEO
- **Gerente de Riesgos** → CEO, con tres gerencias bajo su mando:
 - Gerencia de Innovación de Riesgos (primera línea para los activos que desarrolla).
 - Gerencia de Riesgo Operacional (coordina la evaluación independiente — segunda línea)
 - Subgerencia de Seguridad de la Información (define políticas de seguridad, supervisa cumplimiento y aprueba controles — segunda línea de seguridad).
- **Auditoría Interna** → CEO / Directorio (tercera línea).

Esta estructura es clave: la Subgerencia de Seguridad de la Información **reporta a la Gerencia de Riesgos, no a TI**. TI implementa y verifica técnicamente los controles de seguridad en la infraestructura y el pipeline; la Subgerencia de Seguridad de la Información define las políticas, supervisa el cumplimiento, aprueba los resultados del Ethical Hacking, el Check-list de seguridad y evalúa los riesgos de seguridad de forma independiente.

La Política formaliza la aplicación del modelo de tres líneas de defensa al desarrollo de aplicaciones por áreas de negocio. Define explícitamente quién opera (primera línea), quién evalúa de forma independiente (segunda línea) y quién audita (tercera línea), con especial atención a la separación entre la Gerencia de Innovación de Riesgos, la Gerencia de Riesgo Operacional y la Subgerencia de Seguridad de la Información. Dado que estas tres unidades reportan al mismo Gerente de Riesgos, la Política establece los mecanismos formales de mitigación de esa tensión organizacional, incluyendo la aprobación del GIR por el Comité de Riesgos como instancia superior. La Política incluye asimismo una tabla de asignación de roles por línea y una cláusula de extensión a otras áreas de negocio que adopten el modelo.

Tensión organizacional: Innovación de Riesgos y Riesgo Operacional reportan al mismo Gerente: Dado que la Gerencia de Innovación de Riesgos (primera línea del desarrollo) y la Gerencia de Riesgo Operacional (segunda línea evaluadora) reportan ambas al mismo Gerente de Riesgos, existe una tensión organizacional inherente. Esta tensión se mitiga mediante: (a) la separación formal de funciones entre ambas gerencias, documentada en el OLA y en la política marco; (b) el rol del Comité de Riesgos como instancia de aprobación del GIR, por encima del Gerente de Riesgos; y (c) la revisión de Auditoría Interna como tercera línea de defensa independiente. El modelo no elimina esta tensión, pero la gestiona con controles explícitos.

9.2 Modelo proveedor interno

La Política establece formalmente que la Gerencia de Innovación de Riesgos será tratada, para efectos de gobierno tecnológico, como un proveedor interno sujeto a los mismos controles que un proveedor externo de software. TI evalúa sus entregables como "caja negra": no revisa la lógica de negocio ni el código fuente de la aplicación, pero sí exige controles de seguridad, documentación y pase a producción equivalentes a los de cualquier tercero. El instrumento que formaliza esa relación es el OLA interno.

Definición operativa: "El área de Innovación de Riesgos será tratada, para efectos de gobierno tecnológico, como un proveedor interno sujeto a los mismos controles que un proveedor externo de software."

9.3 Política marco — articulado

La Política contiene nueve artículos:

1. **Alcance y origen del modelo** — aplica a la Gerencia de Innovación de Riesgos; extensible a otras unidades por resolución del Comité de Riesgos y TI.
2. **Clasificación del entregable y revisión de seguridad** — las aplicaciones se tratan como software de proveedor externo; TI implementa controles automáticos (SAST, SCA, secretos); la Subgerencia de Seguridad de la Información define políticas, aprueba resultados y supervisa el cumplimiento.
3. **Responsabilidades y propiedad** — la Gerencia de Innovación de Riesgos es Responsable de Aplicación; TI es Custodio de Infraestructura; la Subgerencia de Seguridad de la Información ejerce la supervisión de segunda línea. Roles registrados en CMDB.
4. **Infraestructura y prohibición de despliegue externo** — toda infraestructura en AWS bajo gobierno de TI; prohibición absoluta de despliegue fuera de la infraestructura de Efectiva.
5. **Herramientas, plataformas y preferencia por el stack existente** — uso preferente del stack actual; cualquier excepción requiere justificación formal ante el Comité de Arquitectura; para componentes de IA, aprobación previa del Comité de Gobierno de IA.
6. **Segregación de roles (tres líneas de defensa)** — el equipo que desarrolla no puede emitir el GIR ni aprobar el pase a producción como segunda línea.

7. **Metodología y gestión de proyectos** — toda metodología utilizada debe estar formalmente normada dentro de Efectiva antes de su aplicación.
8. **Política de IA, Comité de Gobierno de IA y exfiltración de datos** — cumplimiento obligatorio de la Política de Seguridad en el Uso de IA; aprobación del Comité de Gobierno de IA para componentes de IA críticos; prohibición de envío de datos a servicios externos sin contrato formal.
9. **Estándares de seguridad** — cumplimiento de OWASP Top 10, OWASP LLM Top 10 (para componentes de IA/chatbot) y NIST SSDF; cifrado obligatorio de datos personales en tránsito y en reposo.

9.4 Mesa ágil e integraciones con el ecosistema TI

La Política define la Mesa Ágil TI-Innovación de Riesgos como el mecanismo formal para gestionar las integraciones entre las aplicaciones de negocio y el ecosistema institucional (Core Bancario, ODM, Directorio Activo, servicios de correo y SMS, entre otros). Establece que el desarrollo de las integraciones es responsabilidad de TI, mientras que la Gerencia de Innovación de Riesgos define los requerimientos funcionales. Fija también las obligaciones de adaptación de Innovación de Riesgos ante cambios en las integraciones gestionadas por TI.

9.5 Control de dominios y gobierno de internet

Como respuesta directa al incidente de seguridad documentado en el Capítulo 1, la Política prohíbe el uso de dominios externos no registrados en el inventario de TI, establece el monitoreo activo de dominios con términos relacionados con la marca Efectiva, y centraliza en TI la gestión del DNS para todas las aplicaciones institucionales, independientemente de quién las desarrolló.

9.6 OLA — Acuerdo Operativo de Servicio

La Política incluye el marco completo del OLA, articulado en tres secciones: (A) servicios comprometidos por TI hacia la Gerencia de Innovación de Riesgos, con SLAs definidos para infraestructura AWS, pipeline CI/CD, monitoreo, soporte y mesa ágil; (B) obligaciones de la Gerencia de Innovación de Riesgos, incluyendo plazos de remediación de vulnerabilidades (72 horas para críticas, 30 días para altas), participación en DRP, mantenimiento de documentación y registro en CMDB; y (C) el protocolo de acceso de emergencia (break-glass), con supervisión activa de TI durante cualquier acceso excepcional a producción.

9.7 Gestión de incidentes y soporte

La gestión de incidentes de las aplicaciones desarrolladas bajo el modelo Business-IT se rige por los protocolos institucionales de Mesa de Ayuda ya vigentes en Efectiva. Al ser Innovación de Riesgos un "proveedor interno", aplican los mismos controles de registro, escalamiento y flujo de incidentes que con proveedores externos de software.

El criterio de derivación en el contexto Business-IT es el siguiente:

- Incidentes de infraestructura o plataforma (disponibilidad, red, pipeline, ambientes AWS) → TI / Infraestructura
- Incidentes de lógica de aplicación, datos o comportamiento funcional → Innovación de Riesgos

Cuando el origen no es claro: se requiere un descarte simultáneo entre TI e Innovación de Riesgos, coordinado por Mesa de Ayuda / Jefatura de Soporta a Usuarios y Mesa de Ayuda. Los SLAs de atención para cada parte quedan establecidos en el OLA.

9.8 Checklist de pase a producción

La Política define cinco grupos de gobierno que toda aplicación debe acreditar antes del pase a producción:

- (1) Documentación: evidencia de que la aplicación está suficientemente documentada para su operación, mantenimiento y auditoría;
- (2) Seguridad: conformidad formal emitida por la Sub-gerencia de Seguridad de la Información, que actúa como condición necesaria y puerta de bloqueo;
- (3) Privacidad — evidencia de cumplimiento de las obligaciones de protección de datos personales aplicables (DS 016-2024-JUS y Ley 29733);
- (4) Riesgo Operacional: GIR multidisciplinario coordinado por Riesgo Operacional y aprobado por el Comité de Riesgos; y
- (5) Pruebas y Control de Cambios: evidencia de pruebas en ambiente equivalente a producción y aprobación formal del CAB. Para aplicaciones Tier 3 (canal externo crítico), todos los grupos son obligatorios sin excepción.

Nota: Esta normativa establece el qué (los grupos de gobierno obligatorios) y el quién (los responsables de cada grupo). Los controles técnicos específicos dentro de cada grupo —herramientas, estándares, umbrales y criterios de aprobación— son definidos y mantenidos por la Política de Seguridad de la Información, la metodología CI/CD vigente y los procedimientos de pase a producción institucionales. Esta normativa no los redefine ni los reemplaza; se alinea a ellos. Ante cualquier discrepancia, prevalece lo establecido en dichos instrumentos.

9.9 Criterios de rechazo automático

La Política establece criterios de bloqueo absoluto en el pipeline de pase a producción. Ninguna aprobación de negocio o presión de tiempo puede sobrepasarlos. Se distinguen dos categorías:

- (1) **Criterios de gobierno propios de esta normativa:** son condiciones de cumplimiento que esta normativa define directamente:
 - Ausencia del GIR aprobado por el Comité de Riesgos.
 - Ausencia de conformidad formal de la Subgerencia de Seguridad de la Información (Grupo 2 del checklist).
 - Componentes de IA no aprobados por el Comité de Gobierno de IA.
 - Datos reales de clientes en ambientes de desarrollo o QA.
 - Dominio no registrado en el inventario de TI.
 - Exfiltración de datos a servicios externos sin contrato formal.
 - Metodología de desarrollo no normada formalmente en Efectiva.
- (2) **Criterios de seguridad técnica:** son condiciones cuya definición, umbrales y verificación son competencia de la Subgerencia de Seguridad de la Información y de la metodología CI/CD vigente. Esta normativa los reconoce como causales de bloqueo, pero no los define ni los reemplaza:
 - Vulnerabilidad de seguridad crítica activa sin plan de remediación aprobado
 - Credenciales o secretos expuestos en el código fuente
 - Ausencia de Ethical Hacking vigente para la aplicación o cambio que lo requiera
 - Ausencia de cifrado de datos personales según estándares vigentes
 - Otros controles técnicos determinados por la Política de Seguridad de la Información o la metodología CI/CD, que la Subgerencia de Seguridad de la Información declare como bloqueantes para un despliegue específico.

Nota: La Subgerencia de Seguridad de la Información puede incorporar, modificar o elevar criterios de rechazo técnico sin necesidad de modificar esta normativa. Lo que esta normativa establece con carácter permanente son los criterios de gobierno: ausencia de GIR, ausencia de conformidad de Seguridad de la Información, componentes de IA no aprobados, y los demás listados en la primera categoría.

9.10 Comité de Arquitectura

La Política define el Comité de Arquitectura como un órgano de evaluación técnica —no de gobierno de IA— con un proceso de homologación de 15 días hábiles. Establece su composición (presidido por el Gerente de TI, con participación de Seguridad de la Información como segunda línea, Innovación de Riesgos, Arquitectura TI, Infraestructura Cloud y Cumplimiento), su proceso en cuatro pasos (solicitud, revisión técnica, sesión y publicación en catálogo), y el principio de preferencia por el stack existente. Para componentes de IA, el dictamen del Comité de Gobierno de IA es condición previa a la evaluación del Comité de Arquitectura.

9.11 Clasificación de aplicaciones (Risk Tiering)

La Política establece tres categorías de aplicaciones con controles progresivos:

Nivel	Descripción
Tier 1 (interno bajo riesgo)	Herramientas analíticas sin conexión al core, con controles mínimos de inventario y documentación.
Tier 2 (interno sensible)	Aplicaciones con acceso a datos confidenciales y sistemas corporativos, con Ethical Hacking periódico según criterio de Seguridad de la Información y segregación de ambientes.
Tier 3 (canal externo crítico)	Aplicaciones internet-facing con datos de clientes y uso de IA —categoría en la que se ubica el canal web y chatbot de Innovación de Riesgos—, con la aplicación íntegra de todos los grupos del Checklist, Ethical Hacking con la periodicidad definida por Seguridad de la Información, cifrado de datos personales en tránsito y en reposo según estándares vigentes, logs con trazabilidad por el período exigido por la normativa aplicable, Oficial de Datos, aprobación del Comité de Gobierno de IA y cobertura en BCP/DRP. El tier debe quedar registrado en el CMDB / Inventario de aplicaciones.

9.12 Datos personales y privacidad

La Política detalla los controles obligatorios para el tratamiento de datos personales en el canal de crédito digital: cifrado end-to-end (TLS 1.2 en tránsito, AES-256 en reposo), segregación estricta de ambientes con prohibición absoluta de datos reales en desarrollo y QA, logs de trazabilidad de 2 años, gestión de acceso mínimo con revisión semestral, prohibición de exfiltración a servicios externos no autorizados, y designación del Oficial de Datos Personales. Precisa que estos controles son parte integral del checklist de Seguridad de la Información y del GIR, no requerimientos paralelos independientes.

9.13 Rol de la Seguridad de la Información

La Política dedica una sección específica a clarificar que la Subgerencia de Seguridad de la Información reporta a la Gerencia de Riesgos, no a TI, y actúa como segunda línea independiente en el modelo. Define sus responsabilidades: definir políticas de seguridad, aprobar herramientas y plataformas, supervisar el cumplimiento del ciclo de vida, aprobar el Ethical Hacking, emitir el checklist de conformidad de seguridad (insumo obligatorio del GIR), participar en el Comité de Arquitectura como representante de segunda línea, y revisar la Política de IA. Incluye también una tabla de separación de funciones TI/Seguridad de la Información para cada actividad del ciclo de gobierno.

9.14 Gobierno de IA

El Comité de Gobierno de Inteligencia Artificial y su marco regulatorio están definidos y cubiertos por la Política de Seguridad en el Uso de Inteligencia Artificial de Efectiva. Esta normativa Business-IT no redefine ni reemplaza dicha política — únicamente se alinea a ella y la referencia como condición de gobierno para los componentes de IA desarrollados bajo el modelo Business-IT.

La Política formaliza el Comité de Gobierno de Inteligencia Artificial como órgano de aprobación de alto nivel para el uso de IA en Efectiva. Establece sus funciones (clasificar sistemas, autorizar los de riesgo alto, validar controles de mitigación, supervisar riesgos emergentes), señala que el chatbot y el scoring crediticio de Innovación de Riesgos son de riesgo alto por definición de la Política de IA y requieren autorización expresa del Comité. Define la separación de funciones entre el Comité de Gobierno de IA (riesgo, ética, cumplimiento) y el Comité de Arquitectura (compatibilidad técnica), con el primero como condición previa al segundo. Incluye una tabla de controles específicos para el uso de IA (restricción de envío de datos a LLMs externos, control de prompts en producción, revisión humana del código generado por IA, inventario de modelos, monitoreo de drift, XAI) y la lista de riesgos OWASP LLM Top 10 aplicables al chatbot.

9.15 Metodología de desarrollo y gestión de proyectos

La Política establece que toda metodología de desarrollo de software o gestión de proyectos utilizada por La Gerencia de Innovación de Riesgos debe estar formalmente normada dentro de Efectiva antes de su aplicación. Si el equipo adopta una metodología no contemplada en las normas actuales, debe completar un proceso de normalización que incluye documentación formal, aprobación por TI y revisión de Cumplimiento o Auditoría Interna cuando corresponda. Una metodología no normada constituye un hallazgo potencial en auditorías de la SBS.

9.16 Tipos de cambio y controles aplicables

La clasificación de los pases a producción y los controles de aprobación asociados se rigen por lo establecido en el **MPP.2025.TYO.020.02 — Desarrollo de Software**, que define tres categorías: Pase Normal, Pase Prioritario y Cambio de Urgencia. Esta normativa no redefine esa clasificación sino que la complementa precisando los controles adicionales exigibles en el contexto Business-IT para cada categoría:

Categoría (MPP)	Controles adicionales en el contexto Business-IT
Pase Normal	Checklist completo de pase a producción (Grupos 1 al 5, sección 7.7), GIR aprobado por el Comité de Riesgos cuando aplica por criterio de riesgo operacional, pipeline automatizado (SAST, SCA, secrets scanning)
Pase Prioritario	Pipeline automático, aprobación CAB con registro formal, plan de rollback documentado. Los controles de seguridad no se omiten; se aplican los disponibles en el pipeline automatizado
Cambio de Urgencia	Aprobación del Gerente de TI o Subgerente de Infraestructura y TI conforme al MPP. Informe posterior a Seguridad de la Información. Registro obligatorio en CMDB. Regularización en el Acta de la siguiente Reunión de Pases a Producción

La definición de cuándo aplica el Ethical Hacking es competencia de la Subgerencia de Seguridad de la Información, en el marco de su Política de Seguridad. Como referencia general: el Ethical Hacking aplica al despliegue inicial de toda aplicación y a cambios que amplíen la superficie de ataque (nuevas APIs expuestas, nuevos canales, nuevas integraciones con datos de clientes). No aplica de forma rutinaria a correctivos menores ni a mejoras que no alteren la arquitectura de seguridad.

La Subgerencia de Seguridad de la Información puede elevar los controles exigibles para cualquier cambio específico si su evaluación de riesgo así lo determina, independientemente de la categoría asignada en esta tabla. También se establece revisiones de Ethical Hacking anuales o semestrales sobre aplicaciones críticas en Producción.

10. Plan de acción

Esta normativa entra en vigor desde la fecha de su aprobación formal. El plan de acción que se propone no es una condición previa ni una moratoria: es el horizonte para alcanzar la madurez completa del modelo, incluyendo la implementación del pipeline CI/CD automatizado, la consolidación de controles y la primera evaluación de mejoras.

Desde el día uno de vigencia, los principios y controles de gobierno establecidos en esta normativa son de cumplimiento obligatorio. Los pases a producción se realizan con los controles ya operativos en cada fase del plan. Los controles aún no implementados forman parte del backlog del plan de acción y tienen responsable y plazo asignados en la tabla siguiente.

Fase	Actividades	Responsable	Plazo
Fase 0 — Inventario	Catalogar todas las apps actuales de Innovación de Riesgos. Verificar que no existan despliegues fuera de infraestructura Efectiva. Asignar tier. Activar monitoreo de dominios.	TI + Innovación de Riesgos	Semanas 1–2
Fase 1 — Fundamentos	Aprobar política marco en Comité de Riesgos y TI. Firmar OLA v1.0. Constituir Comité de Arquitectura y confirmar estructura del Comité de Gobierno de IA. Publicar catálogo inicial de herramientas pre-aprobadas. Verificar normalización de metodología de desarrollo. Actualizar el MPP (Manual de Políticas	Gerente de TI / Gerente de Riesgos	Semanas 3–6

Fase	Actividades	Responsable	Plazo
	y Procedimientos) para incorporar el modelo Business-IT y sus instrumentos de gobierno.		
Fase 2 — Remediación	Aplicar Checklist a apps Tier 3 ya en producción. Iniciar Ethical Hacking + SCA. Registrar todas en CMDB. Verificar segregación de ambientes y ausencia de datos reales en dev/QA. Obtener conformidad formal de Seguridad de la Información para apps existentes.	TI + Subgerencia de Seguridad de la Información + Innovación de Riesgos	Meses 2-4
Fase 3 — Pipeline CI/CD	Implementar Camino Estándar en AWS (multi-account, Control Tower). Pipeline con gates automáticos (SAST, SCA, secrets scanning). Configurar ambientes separados dev/QA/prod. Deshabilitar acceso directo de Innovación de Riesgos a producción. Activar Session Manager.	TI DevOps	Meses 3-5
Fase 4 — Mesa ágil	Constituir la mesa ágil TI-Innovación de Riesgos. Definir backlog de integraciones (Core, ODM, DA, servicios esenciales). Documentar versionado de APIs expuestas. Implementar gobierno de DNS.	TI + Innovación de Riesgos	Meses 2-4
Fase 5 — Madurez	Primera revisión anual del OLA. Medición de KPIs del modelo. Evaluación de extensión a otras unidades. Revisión del catálogo de herramientas aprobadas	Gerente de TI + Gerente de Riesgos	Mes 12

Fase	Actividades	Responsable	Plazo
	incluyendo componentes de IA. Revisión con el Comité de Gobierno de IA.		

Nota: Esta normativa entra en vigor desde su aprobación y el plan de 12 meses es el horizonte de madurez progresiva, no una condición para que los controles existan. Durante ese período los pases a producción se realizan con los controles ya operativos en cada fase, y que los que aún no estén implementados serán parte de las mejoras del plan, especialmente los que se derivan de la metodología e implementación de CI/CD.

11. Registro de riesgos del modelo

Número	Riesgo	Probabilidad	Impacto	Estado	Control
R-01	Repetición del incidente: app desplegada fuera de infraestructura Efectiva	Media	Crítico	Abierto	Prohibición explícita en política. Gobierno de DNS. Monitoreo de dominios. Cláusula en OLA.
R-02	Canal externo sin análisis de vulnerabilidades (SBS 504-2021)	Media	Crítico	Abierto	Gate obligatorio en checklist Grupo 2: pentest + SCA.
R-03	Incumplimiento DS 016-2024-JUS: logs 2 años, trazabilidad, Oficial de Datos	Media	Crítico	Abierto	Gate de privacidad en Checklist Grupo 3. CloudWatch retención 2 años.
R-04	Envío de datos a LLMs externos sin contrato formal (exfiltración)	Alta	Crítico	Abierto	Criterio de rechazo automático. Art. 8 de la política marco. Política de Seguridad en el Uso de IA. Comité de Gobierno de IA.
R-05	Componentes de IA no aprobados por el Comité de Gobierno de IA o no alineados con la Política de Seguridad en el Uso de IA	Alta	Crítico	Abierto	Criterio de rechazo automático. OWASP LLM Top 10 checklist. Flujo de aprobación: Comité de Gobierno de IA → Seguridad de la Información → Comité de Arquitectura.

Número	Riesgo	Probabilidad	Impacto	Estado	Control
R-06	Sesgo algorítmico en modelos IA crediticia sin evaluación independiente	Media	Crítico	Abierto	Evaluación periódica por Gerencia de Riesgo Operacional. XAI documentado. Aprobación del Comité de Gobierno de IA.
R-07	Datos reales de clientes en ambientes de desarrollo o QA	Media	Crítico	Abierto	Criterio de rechazo automático. Segregación estricta de ambientes. Verificación en checklist.
R-08	Ambigüedad de responsabilidad ante SBS en incidente	Media	Crítico	Abierto	OLA con roles explícitos en CMDB (Responsable de Aplicación / Custodio de Infraestructura). Separación TI vs. Seguridad de la Información documentada.
R-09	Key-man risk: desarrollador clave deja la Gerencia de Innovación de Riesgos	Media	Crítico	Abierto	Documentación obligatoria como gate. Mínimo 2 responsables por app.
R-10	Metodología de desarrollo de Innovación de Riesgos no normada — observación SBS	Media	Alto	Abierto	Normalización formal antes de inicio del proyecto. Ver sección 7.13.
R-11	Deuda técnica en librerías/modelos IA no actualizada	Alta	Alto	Abierto	SLAs de remediación en OLA. Revisión anual. SCA automático en pipeline.
R-12	Independencia de evaluación comprometida (tres líneas): Innovación de Riesgos y Riesgo Operacional reportan al mismo Gerente	Media	Alto	Mitigado	Separación formal de funciones documentada. GIR aprobado por Comité de Riesgos (por encima del Gerente de Riesgos). Auditoría Interna como tercera línea. Ver sección 7.0.
R-13	Fricción en Comité de Arquitectura genera shadow IT paralelo	Media	Medio	Abierto	SLA 15 días. Catálogo pre-aprobado. Camino Estándar reduce solicitudes.

Número	Riesgo	Probabilidad	Impacto	Estado	Control
R-14	Proliferación: otras áreas exigen el mismo tratamiento sin controles	Media	Medio	Mitigado	Política marco aprobada por Directorio con alcance delimitado.
R-15	Ausencia de conformidad formal de Seguridad de la Información bloquea el pase a producción sin proceso claro	Media	Alto	Abierto	Criterio de rechazo explícito en sección 7.7. Checklist Grupo 2 con conformidad formal como item obligatorio. SLA de revisión a definir en OLA.

Próximas iteraciones de este documento: Pendiente para iteraciones futuras: (a) plantillas de formularios del Comité de Arquitectura y del Comité de Gobierno de IA; (b) texto contractual completo del OLA con firmas; (c) KPIs del modelo con línea base y metas; (d) procedimiento detallado del protocolo de acceso de emergencia con script de Session Manager; (e) plan de capacitación en desarrollo seguro para el equipo de Innovación de Riesgos; (f) checklist completo OWASP LLM Top 10 para el chatbot; (g) definición de datos sintéticos y procedimiento de anonimización para dev/QA; (h) composición formal y reglamento del Comité de Gobierno de IA.